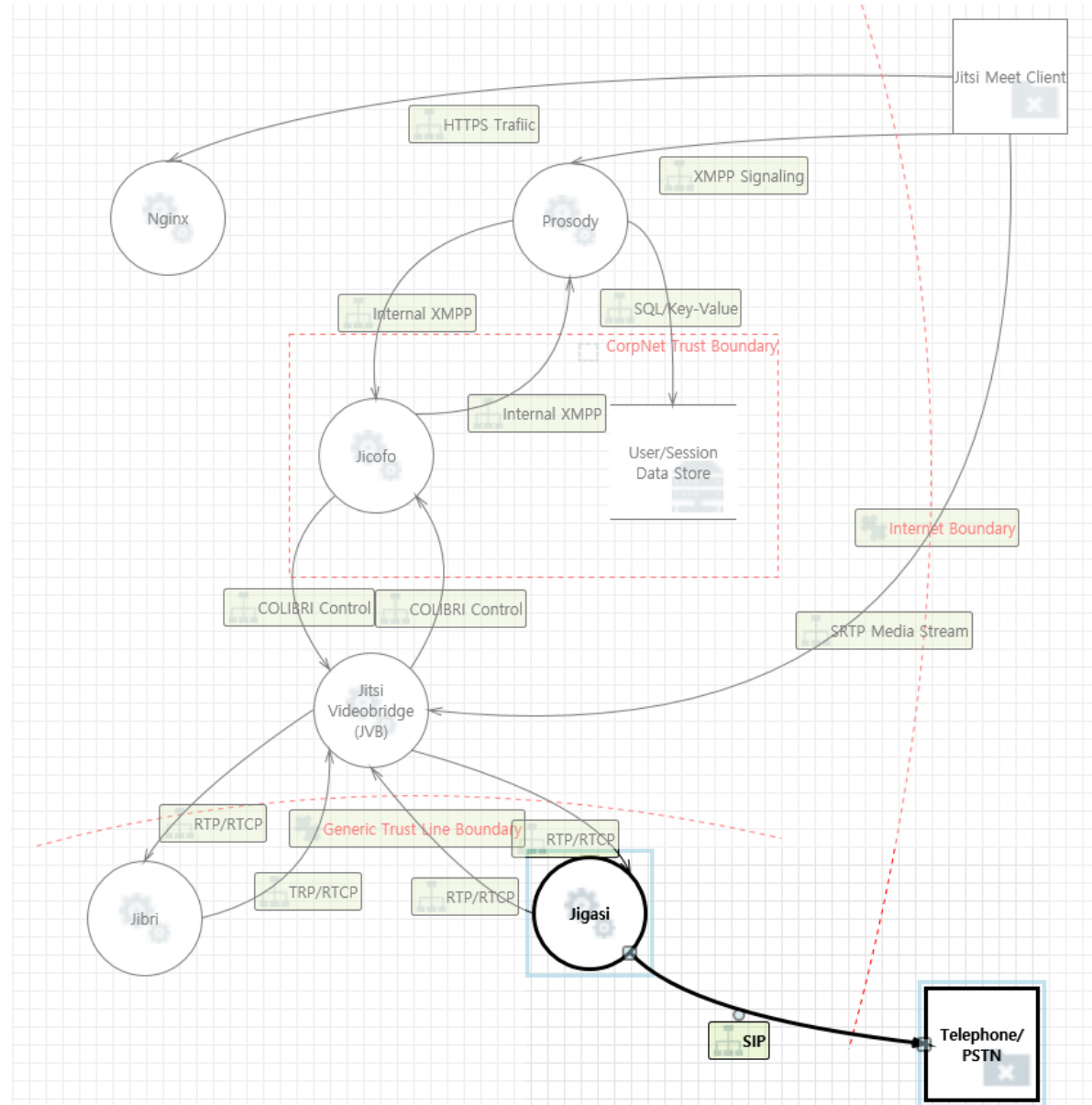
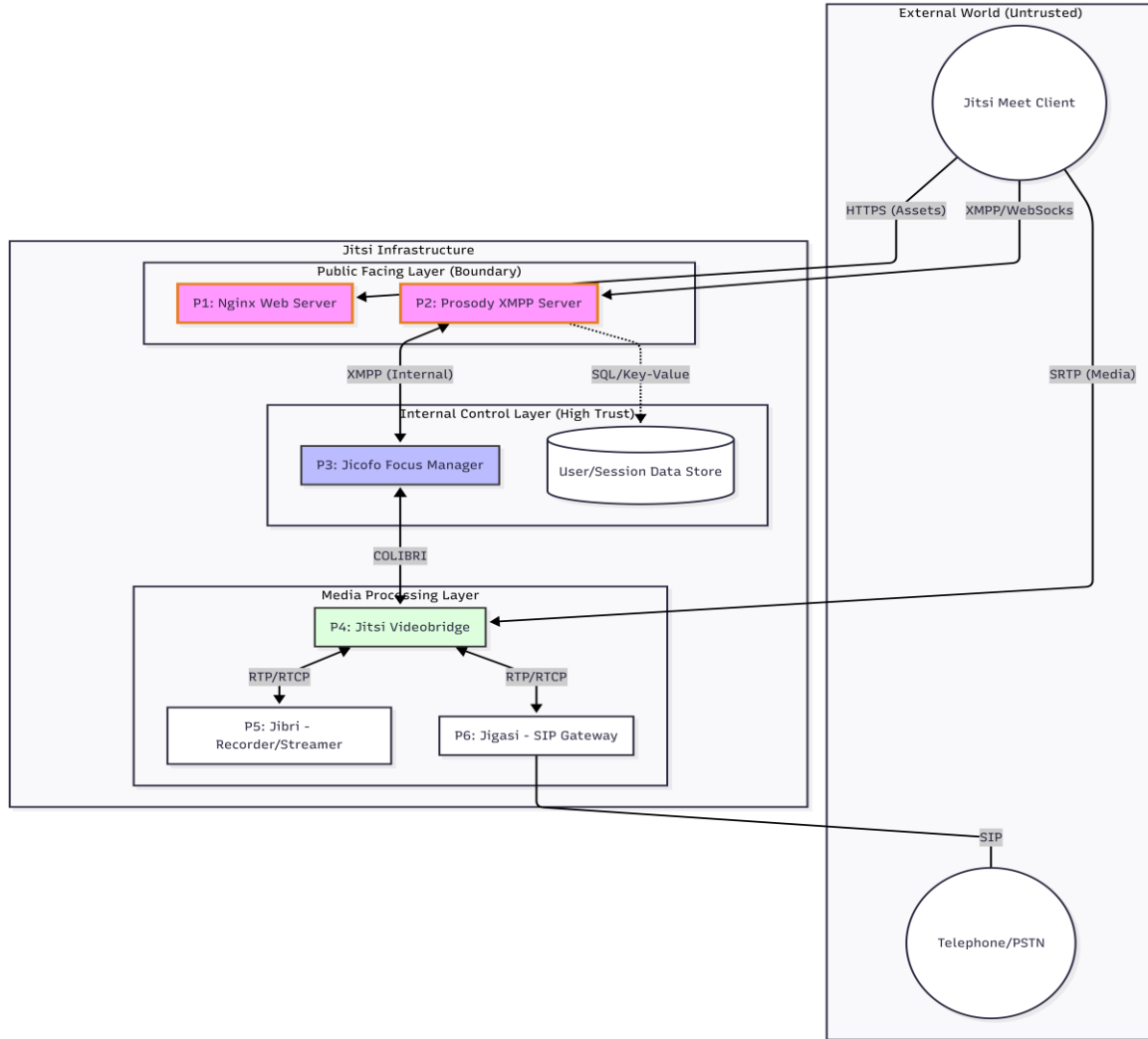


1조 실험그룹 A조

Jitsi Meet DFD

두개의 DFD산출 (형식은 달라도 내용은 비슷함)



강의노트 기반 STRIDE

위협유형	위협시나리오	영향을 받는 요소	보안목표
S	공격자가 다른 사용자의 자격 증명을 탈취해 회의에 참여하려고 함	P2:Prosody	인증
T	클라이언트 ↔ Nginx 구간의 XMPP메세지를 변조함	시그널링흐름	무결성
I	암호화 되지 않은 SRTP 패킷을 중간에 도청함	P4:JVB	기밀성
D	표준문법형식을 따르지 않은 JSON 을 보내 서버를 마비시킴	P2:Prosody	가용성
E	일반 참여자가 관리자 권한을 획득해 타인을 강퇴함	P3:Jicofo	권한부여

Microsoft Threat Modeling Tool 기반 STRIDE

위협유형	위협시나리오	영향을 받는 요소	보안목표
S	사용자의 로그인 세션이나 중요한 개인정보가 저장되는 데이터베이스(DB)를 사칭하는 위협	User/Session Data Store	인증
T	제어 패킷에 검증되지 않은 악성 문자열을 주입하여 미디어 서버 데이터 오염 및 오작동을 유도합니다	JVB	무결성
R	작업 기록(로그) 누락을 악용해 보안 사고 발생 시 공격자가 행위를 부인하고 추적을 회피합니다	User/Session Data Store	책임추적성확보
I	내부 통신 구간을 암호화하지 않아 네트워크 스니핑으로 민감한 회원 정보를 그대로 도청당합니다	SQL/Key-Value	기밀성보장
D	대량의 신호나 치명적인 페이로드로 서버 리소스를 고갈시켜 모든 화상회의를 중단하고 가용성을 마비시킵니다	JVB	가용성확보
E	사용자 브라우저를 속여 위	CSRF	인가통제

STRIDE를 기반으로 DREAD점수 부여

- 강의노트 기반의 DREAD점수

	S	T	I	D	E
D(피해가능성)	8	6	9	9	7
R(재현성)	7	5	8	10	6
E(악용가능성)	6	5	6	8	5
A(영향받는사용자)	7	10	10	10	10
D(발견 가능성)	8	6	7	8	6

STRIDE를 기반으로 DREAD점수 부여

- Tool 기반의 DREAD점수

	S	T	R	I	D	E
D(피해가능성)	10	9	6	9	9	8
R(재현성)	7	8	5	7	10	7
E(악용가능성)	6	10	5	6	8	7
A(영향받는사 용자)	10	7	4	10	10	8
D(발견 가능성)	7	8	7	6	8	7

총 DREAD 점수

총점10점 critical > high > medium > low

순위	위협 유형	위협 시나리오 (핵심 요약)	영향 요소	D	R	E	A	D	평균	위협 등급
1	D	대량 신호 및 악성 JSON을 이용한 서버 마비 (DoS) PDF	Prosody / JVB	9	10	8	10	8	9	Critical
2	E	JVB(미디어 서버)에서의 원격 코드 실행 (RCE)	P4: JVB	10	9	8	10	7	8.8	Critical
3	S	웹 서버(Nginx) 사칭 및 클라이언트 정보 유출 PDF	P1: Nginx	9	8	7	10	8	8.4	High
4	T	미디어 제어 패킷에 악성 문자열 주입 및 오작동 유도	P4: JVB	9	8	7	10	8	8.4	High
5	S	데이터 저장소(DB) 사칭을 통한 자격 증명 탈취 PDF	Data Store	10	7	6	10	7	8	High
6	I	미디어 패킷(SRTP) 또는 내부 SQL 구간 도청 PDF	JVB / SQL	9	8	6	10	6	7.8	High
7	E	CSRF 또는 권한 상승을 통한 회의 제어권 탈취 PDF	P3: Jicofo	8	7	7	8	7	7.4	High
8	S	전화망(PSTN) 개체 사칭 및 데이터 타겟팅 PDF	Jigasi	7	6	5	4	9	6.2	Medium
9	R	로그 누락을 악용한 공격 행위 부인 및 회피 PDF	Data Store	6	5	5	4	7	5.4	Medium

위협 대응방안

- 암호화 : DTLS – SRTP방식 적용
- 가용성 확보 : Nginx 의 Rate Limiting 적용
- 입력값 검증 : Malformed Json 차단을 위한 로직 적용